

Domain: Retail Payments | Statutory Architecture

1. System Scope & Stakeholder Requirement Statement

[illegible]

Pillar: Frontend & Mobile UI/UX (5 Specifications)

Confidential — Indian Banking & Financial Systems Architecture Page 1 of 8

REQ-FE-01	UPI Recurring Mandate System — Responsive Client Interface & Intent Layer Provide intuitive, accessible digital interfaces for stakeholders of UPI Recurring Mandate System with real-time feedback and sub-250ms screen transition latency.	Must Have	Regulation: RBI Digital Payment Security Controls Sec 4 Acceptance: <i>Renders complete workflow with client-side form validation and latency < 250ms.</i>
REQ-FE-02	Dynamic Multilingual Localization (12 Indian Languages) Implement dynamic multilingual localization (English, Hindi, and regional languages) with offline draft persistence and sync-on-reconnect.	Should Have	Regulation: Digital Personal Data Protection Act, 2023 (Multilingual Consent) Acceptance: <i>Allows offline caching in encrypted storage; synchronizes queued records within 2s of reconnection.</i>
REQ-FE-03	Digital KYC Document Uploader & Real-Time Verification Deliver secure client-side document capture with image compression, edge blur detection, and instant verification feedback.	Must Have	Regulation: RBI KYC Master Direction & Information Technology Act 2000 Acceptance: <i>Validates document MIME-types and enforces 5MB limit; rejects blurry uploads client-side.</i>
REQ-FE-04	Interactive Audit Trail & Activity Dashboard Provide interactive dashboard displaying real-time transaction statuses, pending approvals, and downloadable account statements.	Should Have	Regulation: RBI Fair Practices Code & Customer Protection Norms Acceptance: <i>Displays real-time transaction timeline with instant PDF statement download.</i>
REQ-FE-05	Session Security & Device Fingerprint UI Controls Enforce device fingerprint binding, automated background biometric re-authentication prompts, and visual privacy watermarks on all sensitive screens.	Must Have	Regulation: RBI Digital Payment Security Controls Sec 4.3 Acceptance: <i>Detects root/emulator status at launch; triggers graceful lock with user guidance.</i>

Pillar: Backend Architecture & Core APIs (7 Specifications)

Req ID	Title & Detailed Specification	Priority	Statutory Citation & Acceptance Criteria
REQ-BE-01	Enable UPI Auto-Pay Setup The application allows users to configure an automated payment method using their chosen UPI app for merchant services.	Must Have	Regulation: BHIM UPI Guidelines 2026 Acceptance: <i>Users can select a preferred UPI app and enable auto-pay for merchant services.</i>
REQ-BE-02	Automatic Debit Functionality Once configured, the application initiates automatic debits from the user's bank account based on the pre-set amount and frequency.	Must Have	Regulation: Statutory Compliance Directive Acceptance: <i>The application successfully performs automatic debits according to the user's preferences.</i>
REQ-BE-03	Core Microservices & High-Throughput Switch Engine Deploy modular, low-latency microservices orchestrating primary business workflows with transactional atomicity, idempotent request handling, and REST/gRPC API contracts.	Must Have	Regulation: RBI Core Banking Architecture Guidelines Acceptance: <i>Maintains idempotent processing with unique UUID key checks; enforces 99.95% API uptime.</i>
REQ-BE-04	High-Throughput Asynchronous Event Streaming Pipeline Integrate an event-driven streaming pipeline (Kafka/RabbitMQ) for asynchronous notification dispatch, ledger state transitions, and audit telemetry.	Must Have	Regulation: RBI Cyber Security Architecture Guidelines Acceptance: <i>Processes 10,000 events/second with zero message loss and at-least-once delivery guarantees.</i>
REQ-BE-05	Automated Regulatory Telemetry & FIU-IND Reporting Pipeline Implement automated transaction monitoring generating Cash Transaction Reports (CTR) and Suspicious Transaction Reports (STR) formatted for FIU-IND FINnet 2.0 batch exports.	Must Have	Regulation: Prevention of Money Laundering Act (PMLA 2002) & FIU-IND Reporting Directives Acceptance: <i>Flags suspicious velocity or threshold anomalies (>₹10 Lakhs) within 60 seconds.</i>

REQ-BE-06	External Banking Switch & Partner API Gateway Orchestrate external API integrations (NPCI, sponsor banks, credit bureaus, CKYCR) via mutual TLS (mTLS) with token-bucket rate limiting and circuit breaking.	Must Have	Regulation: RBI Guidelines on Outsourcing & Digital Lending Partner Oversight Acceptance: <i>Restricts unauthorized partner API requests; enforces 150 req/min rate limit per tenant.</i>
REQ-BE-07	Real-Time Automated Reconciliation Engine Deploy automated 2-way and 3-way reconciliation jobs matching application ledger entries against sponsor bank settlement files and clearing reports.	Must Have	Regulation: RBI Harmonisation of Turn Around Time (TAT) and Customer Compensation Acceptance: <i>Identifies discrepancies and triggers automated compensatory reversals within T+1 day.</i>

Pillar: Authentication, Identity & KYC Governance (5 Specifications)

Req ID	Title & Detailed Specification	Priority	Statutory Citation & Acceptance Criteria
REQ-AUTH-01	RBI Video-based Customer Identification Process (V-CIP) Execute automated customer identification with live facial liveness detection, Indian geo-coordinate validation, and real-time PAN verification.	Must Have	Regulation: RBI KYC Master Direction - V-CIP Amendment Acceptance: <i>Rejects recorded spoof video attempts; verifies GPS coordinates within Indian territorial borders.</i>
REQ-AUTH-02	UIDAI Aadhaar Data Vault (ADV) Hardware Security Isolation Store 12-digit Aadhaar numbers exclusively inside an isolated Hardware Security Module (HSM) Aadhaar Data Vault (ADV), substituting database references with tokens and masking first 8 digits.	Must Have	Regulation: UIDAI Aadhaar Data Vault Circular (2017) & Masking Directive Acceptance: <i>Zero plaintext 12-digit Aadhaar numbers persist in operational application tables or logs.</i>
REQ-AUTH-03	Central KYC Registry (CKYCR) & NSDL PAN Verification Query CKYCR and NSDL databases in real time to auto-populate customer verification records with minimum 80% fuzzy name-match scoring.	Must Have	Regulation: PMLA Rules 2005 & CKYCR Operating Guidelines Acceptance: <i>Returns active PAN status and CKYC ID within 2 seconds of query.</i>
REQ-AUTH-04	Dynamic Two-Factor Authentication (AFA) with Device Binding Mandate Additional Factor of Authentication (AFA) binding device IMEI/MAC, registered mobile number, and transaction amount hash for all financial actions.	Must Have	Regulation: RBI Master Direction on Digital Payment Security Controls Sec 4 Acceptance: <i>Terminates active session upon hardware fingerprint mismatch; enforces 180s OTP expiration window.</i>
REQ-AUTH-05	Role-Based Access Control (RBAC) with Maker-Checker Controls Implement fine-grained RBAC with dual-authorization maker-checker workflows for high-value actions, administrative adjustments, and compliance overrides.	Must Have	Regulation: RBI IT Governance & Cyber Security Framework Acceptance: <i>Prohibits maker from approving own transactions; logs tamper-proof authorization signatures.</i>

Pillar: Information Security & Statutory Compliance (6 Specifications)

Req ID	Title & Detailed Specification	Priority	Statutory Citation & Acceptance Criteria
REQ-SEC-01	Secure Communication Between Applications Communication between the application and the UPI-enabled merchant service is secured using industry-standard encryption protocols.	Must Have	Regulation: Statutory Compliance Directive Acceptance: <i>All data transmitted between the application and the merchant service is encrypted using TLS/SSL standards.</i>

REQ-SEC-02	FIPS 140-2 Level 3 HSM Field-Level Encryption Encrypt all sensitive financial PII, account credentials, and transaction secrets at rest using AES-256-GCM managed by certified Hardware Security Modules (HSM).	Must Have	Regulation: RBI Digital Payment Security Controls Sec 5.2 Acceptance: Database backups contain zero plaintext PII; cryptographic keys rotate automatically every 90 days.
REQ-SEC-03	TLS 1.3 In-Transit Transport Security & SSL Pinning Enforce TLS 1.3 with forward-secrecy cipher suites across all endpoints, combined with dynamic certificate pinning on Android and iOS client applications.	Must Have	Regulation: NPCI Mobile Application Security Standards v2.4 Acceptance: Prevents MITM interception proxies from inspecting or modifying client-server payloads.
REQ-SEC-04	Immutable WORM Forensic Audit Logging Maintain tamper-proof, append-only audit logs for all administrative actions, financial transactions, and authentication events with microsecond NTP time sync, preserved for 10 years.	Must Have	Regulation: CERT-In Cyber Security Direction No. 20(3)/2022-CERT-In & PMLA Sec 12 Acceptance: Logs stored in Write-Once-Read-Many (WORM) storage; prevents update or deletion by any system administrator.
REQ-SEC-05	Web Application Firewall (WAF) & Rate Limiting Engine Protect ingress endpoints against OWASP Top 10 vulnerabilities, automated credential stuffing, and volumetric DDoS attacks via adaptive rate limiting.	Should Have	Regulation: OWASP ASVS Level 3 & RBI Cyber Security Guidelines Acceptance: Blocks SQLi, XSS, and command injection at network perimeter; returns HTTP 429 upon rate limit breach.
REQ-SEC-06	Card-on-File Tokenisation (CoFT) & Sensitive Token Lifecycle Implement token lifecycle management replacing sensitive financial identifiers with network tokens issued with explicit consent and de-tokenization controls.	Must Have	Regulation: RBI Tokenisation - Card Transactions Directive (RBI/2021-22/96) Acceptance: Persistent storage contains solely encrypted tokens; raw card/PAN numbers discarded post-authorization.

Pillar: Database Architecture & Data Residency (5 Specifications)

Req ID	Title & Detailed Specification	Priority	Statutory Citation & Acceptance Criteria
REQ-DB-01	100% Sovereign On-Soil Data Localization Host all primary databases, replicas, backups, and transaction logs exclusively within physical data centers located on Indian soil with zero foreign replication.	Must Have	Regulation: RBI Storage of Payment System Data Directive (RBI/2017-18/153) Acceptance: Annual CERT-In empaneled System Audit Report (SAR) certifies 100% data residency inside Indian territory.
REQ-DB-02	ACID Financial Ledger with Double-Entry Bookkeeping Implement relational tables with serializable transaction isolation enforcing double-entry ledger bookkeeping (Sum of Debits == Sum of Credits).	Must Have	Regulation: RBI Core Banking Accounting & Audit Norms Acceptance: Eliminates floating-point rounding errors; rolls back failed atomic transactions without orphan states.
REQ-DB-03	DPDP Act 2023 Multilingual Consent Ledger & 72-Hour Data Erasure Record granular, unbundled consent timestamps and purposes in an immutable ledger, providing automated cascading data anonymization/erasure pipelines upon user revocation.	Must Have	Regulation: Digital Personal Data Protection Act, 2023 Sec 6 & Sec 12 Acceptance: Executes non-statutory data erasure within statutory 72-hour window upon customer consent withdrawal.
REQ-DB-04	Encrypted Archival & Statutory 10-Year Record Retention Orchestrate lifecycle policies archiving transactional and compliance records to cold encrypted storage with scheduled integrity verification hashes.	Must Have	Regulation: PMLA 2002 Sec 12 & Companies Act 2013 Acceptance: Archives records older than 180 days with SHA-256 verification hash; guarantees 10-year retrieval readiness.

REQ-DB-05	High-Availability Synchronous Multi-Zone Clustering (RPO < 1m, RTO < 15m) Deploy active-standby database clusters spanning multiple availability zones with automated failover guarantees achieving RPO < 1 minute and RTO < 15 minutes.	Should Have	Regulation: RBI Business Continuity Management Directive Acceptance: Primary node failure triggers automated promotion of standby replica in <90 seconds with zero data loss.
-----------	--	-------------	--

Pillar: Resilience, Scalability & Disaster Recovery (6 Specifications)

Req ID	Title & Detailed Specification	Priority	Statutory Citation & Acceptance Criteria
REQ-RES-01	Error Handling During Auto-Pay Process The application includes robust error handling mechanisms to manage potential issues such as network failures or insufficient funds.	Must Have	Regulation: Statutory Compliance Directive Acceptance: The application gracefully handles errors and retries failed transactions if necessary.
REQ-RES-02	Circuit Breaker & Graceful Degradation on Switch Gateways Incorporate Resilience4j circuit breakers across all external banking switches and microservices to prevent cascading thread pool exhaustion.	Should Have	Regulation: RBI IT Disaster Recovery & Resilience Guidelines Acceptance: Switch error rate > 50% opens circuit within 5 seconds, returning cached fallback response without thread exhaustion.
REQ-RES-03	Geo-Redundant Disaster Recovery (DR) Site in Alternate Seismic Zone Establish hot/warm secondary Disaster Recovery infrastructure located in a geographically distant Indian seismic zone with biannual live failover drills.	Must Have	Regulation: SEBI CSCRf BCP/DR Mandate & RBI Cyber Security Framework Acceptance: Production workload successfully cuts over to secondary DR site within 2 hours during scheduled drill.
REQ-RES-04	Automated Failed Transaction Reversal & ₹100/Day Compensation Dispatcher Deploy automated reconciliation daemon detecting failed or timed-out transactions and issuing reversals within T+1 day, calculating mandatory statutory delay compensation.	Must Have	Regulation: RBI Harmonisation of TAT & Customer Compensation (2019) Acceptance: Issues customer refund within 24 hours of failure; automatically calculates ₹100/day compensation for delays.
REQ-RES-05	Real-Time Velocity & Anomaly Fraud Detection Engine Deploy rule-based and ML scoring pipelines evaluating transaction frequency, device changes, and geolocation anomalies to flag suspicious transactions prior to settlement.	Could Have	Regulation: RBI Master Direction on Fraud Risk Management Acceptance: Flags high-velocity anomaly within 500ms, triggering mandatory step-up authentication or analyst alert.
REQ-RES-06	Automated Stress Testing & NPCI Certification Test-Bed Harness Embed continuous performance testing pipelines simulating peak Indian festival transaction volumes (minimum 5,000 TPS) with zero message drops.	Should Have	Regulation: NPCI Operational Preparedness Guidelines & SEBI Capacity Norms Acceptance: Sustains 5,000 TPS benchmark with 99th percentile response latency under 300ms.

Pillar: Interface (2 Specifications)

Req ID	Title & Detailed Specification	Priority	Statutory Citation & Acceptance Criteria
REQ-EXT-35	Display Registered UPI Apps When initiating a UPI auto-pay transaction, the application displays a list of registered UPI apps associated with the user's account.	Should Have	Regulation: Statutory Compliance Directive Acceptance: A list of registered UPI apps appears on screen during the auto-pay setup process.
REQ-EXT-36	Prominent Placement of 'Pay by Any UPI App' Button The 'Pay by Any UPI App' button is made highly visible within the UPI section of the application interface.	Must Have	Regulation: Statutory Compliance Directive Acceptance: The 'Pay by Any UPI App' button is clearly displayed and easily accessible within the UPI section.

Pillar: Integration (1 Specifications)

Req ID	Title & Detailed Specification	Priority	Statutory Citation & Acceptance Criteria
REQ-EXT-37	Auto-Detection of Selected UPI App Upon selecting a UPI app for auto-payment, the application automatically detects and configures the settings for the chosen UPI app.	Must Have	Regulation: Statutory Compliance Directive Acceptance: <i>The application recognizes and sets up the selected UPI app for subsequent auto-payments.</i>

Pillar: Notifications (1 Specifications)

Req ID	Title & Detailed Specification	Priority	Statutory Citation & Acceptance Criteria
REQ-EXT-38	Notification Upon Successful Transaction The application sends notifications to the user upon successful completion of an auto-pay transaction.	Should Have	Regulation: Statutory Compliance Directive Acceptance: <i>The user receives confirmation messages after each successful auto-pay transaction.</i>

3. Regulatory & Statutory Grounding (Indian Banking Frameworks)

Framework	Enforcement Level	Statutory Directive / Citation
RBI Digital Payment Security Controls (2021)	Core Banking & Payment Security	RBI Master Direction on Digital Payment Security Controls
NPCI UPI Operating Guidelines & AutoPay Rules	Clearing & Mandate Orchestration	NPCI Procedural Guidelines on UPI Mandates
RBI Sovereign Data Localization Directive (2018)	100% Indian Data Center Mandate	RBI/2017-18/153 Storage of Payment System Data
Digital Personal Data Protection Act, 2023	Customer Consent & Data Governance	DPDP Act 2023, Sections 6 & 8

4. Mandatory Security & Architectural Controls

Control ID	Title & Architecture Specification	Automated Verification Method
CTRL-SEC-01	Retail Cryptographic Transport & Rest Encryption Enforce TLS 1.3 for all in-transit communications and AES-256-GCM for sensitive fields.	Automated security scanning and cryptographic key rotation verification.
CTRL-AUTH-02	Dual-Factor Authentication & Device Fingerprint Binding Mandatory 2FA with device hardware fingerprint binding and session timeout enforcement.	Penetration testing verifying zero session hijack or credential bypass.
CTRL-AUD-03	Statutory Immutable Forensic Audit Logging Maintain append-only WORM audit logs with microsecond NTP timestamps for statutory retention period.	Cryptographic checksum validation & CERT-In audit verification.
CTRL-RES-04	Automated Circuit Breaker & High Availability Failover Deploy Resilience4j circuit breakers and active-standby database failover with RPO < 1m.	Live chaos drill and automated failover switchover test.

5. Traceability Matrix & Recommended SDLC Sprints

Req IDs	Target Sub-Module	SDLC Phase / Gate	Verification Deliverable
REQ-FE-01 - REQ-FE-05	UPI Recurring Mandate System — Frontend & Mobile UI/UX	Sprint 1 / Frontend Milestone	Frontend & Mobile UI/UX Architecture & Verification Suite <i>Automated Integration Test & Security Signoff</i>
REQ-BE-01 - REQ-BE-07	UPI Recurring Mandate System — Backend Architecture & Core APIs	Sprint 2 / Backend Milestone	Backend Architecture & Core APIs Architecture & Verification Suite <i>Automated Integration Test & Security Signoff</i>
REQ-AUTH-01 - REQ-AUTH-05	UPI Recurring Mandate System — Authentication, Identity & KYC Governance	Sprint 3 / Authentication, Milestone	Authentication, Identity & KYC Governance Architecture & Verification Suite <i>Automated Integration Test & Security Signoff</i>
REQ-SEC-01 - REQ-SEC-06	UPI Recurring Mandate System — Information Security & Statutory Compliance	Sprint 4 / Information Milestone	Information Security & Statutory Compliance Architecture & Verification Suite <i>Automated Integration Test & Security Signoff</i>
REQ-DB-01 - REQ-DB-05	UPI Recurring Mandate System — Database Architecture & Data Residency	Sprint 5 / Database Milestone	Database Architecture & Data Residency Architecture & Verification Suite <i>Automated Integration Test & Security Signoff</i>
REQ-RES-01 - REQ-RES-06	UPI Recurring Mandate System — Resilience, Scalability & Disaster Recovery	Sprint 6 / Resilience, Milestone	Resilience, Scalability & Disaster Recovery Architecture & Verification Suite <i>Automated Integration Test & Security Signoff</i>

REQ-EXT-35 - REQ-EXT-36	UPI Recurring Mandate System — Interface	Sprint 7 / Interface Milestone	Interface Architecture & Verification Suite <i>Automated Integration Test & Security Signoff</i>
REQ-EXT-37	UPI Recurring Mandate System — Integration	Sprint 8 / Integration Milestone	Integration Architecture & Verification Suite <i>Automated Integration Test & Security Signoff</i>
REQ-EXT-38	UPI Recurring Mandate System — Notifications	Sprint 9 / Notifications Milestone	Notifications Architecture & Verification Suite <i>Automated Integration Test & Security Signoff</i>